

Security+ 2.3 · Zero-day

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Zero-day (3:02) · [vídeo original ↗](#) · [YouTube ↗](#)

Zero-day = falha que o fabricante NÃO CONHECE — 'zero dias pra se preparar'.
Exploração antes de patch existir. Defesa: SEM defesa direta — compensação: EDR
behavioural, defesa em camadas, threat intelligence, patch ASAP quando sair.

Highlights que a prova cobra

- Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day
- Defesa: behaviour + camadas + compensating control

Dicas de prova

- 'no patch available' = zero-day
- 'exploited before disclosure' = zero-day exploit

Cenário clássico: Cenário: 'atacante explora vulnerabilidade que o fabricante acabou de descobrir e ainda não tem patch' = zero-day.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:
A) CVE pública
B) Zero-day
C) Backdoor
D) Falso positivo

2. Qual tipo de ataque explora vulnerabilidades antes que um patch esteja disponível?

- A)** Ataque de dia zero (Zero-day)
- B)** Ataque DDoS
- C)** Ataque de força bruta
- D)** Ataque Man-in-the-Middle

3. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa: behaviour + camadas + compensating control'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Defesa: behaviour + camadas + compensating control...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'no patch available' = zero-day'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'no patch available' = zero-day...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'exploited before disclosure' = zero-day exploit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'exploited before disclosure' = zero-day exploit...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante explora vulnerabilidade que o fabricante acabou de descobrir e ainda não tem patch' = zero-day.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'atacante explora vulnerabilidade que o fabricante acabou de desco...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa: behaviour + camadas + compensating control'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Defesa: behaviour + camadas + compensating control...

10. Cenário corporativo (Zero-day): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'no patch available' = zero-day'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'no patch available' = zero-day...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) B — Zero-day. Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção.

2) A — Ataque de dia zero (Zero-day). Zero-day é uma vulnerabilidade recém-descoberta que é explorada antes do desenvolvedor ter conhecimento ou lançar correção (dia zero de conhecimento).

3) A — Implementar a solução correspondente: Zero-day: sem patch disponível — nem toda . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day. As demais alternativas configuram violações graves d

4) A — Implementar a solução correspondente: Defesa: behaviour + camadas + compensating. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): Defesa: behaviour + camadas + compensating control. As demais alternativas configuram violações graves de conformidade ou fa

5) C — Implementar a solução correspondente: 'no patch available' = zero-day.... Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): 'no patch available' = zero-day. As demais alternativas configuram violações graves de conformidade ou falhas de controle.

6) A — Implementar a solução correspondente: 'exploited before disclosure' = zero-day e. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): 'exploited before disclosure' = zero-day exploit. As demais alternativas configuram violações graves de conformidade ou falh

7) B — Implementar a solução correspondente: Cenário: 'atacante explora vulnerabilidade. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): Cenário: 'atacante explora vulnerabilidade que o fabricante acabou de descobrir e ainda não tem patch' = zero-day.. As demai

8) B — Implementar a solução correspondente: Zero-day: sem patch disponível — nem toda . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): Zero-day: sem patch disponível — nem toda exploit conhecida é zero-day. As demais alternativas configuram violações graves d

9) D — Implementar a solução correspondente: Defesa: behaviour + camadas + compensating. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): Defesa: behaviour + camadas + compensating control. As demais alternativas configuram violações graves de conformidade ou fa

10) B — Implementar a solução correspondente: 'no patch available' = zero-day.... Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Zero-day): 'no patch available' = zero-day. As demais alternativas configuram violações graves de conformidade ou falhas de controle.

